

SEGURANÇA DE SISTEMAS DE INFORMAÇÃO

Mecanismos de Segurança

Aula 04 — Da Análise de Ameaças à Proteção em Camadas

Prof. de Segurança da Informação • Módulo Técnico Avançado

Revisão & Evolução do Curso

O que construímos até aqui?

- **Aula 01 (Fundamentos):** Tríade CIA (Confidencialidade, Integridade, Disponibilidade), Não-repúdio e Autenticidade.
- **Aula 02 (Ameaças & Malware):** Análise de Vulnerabilidades, Trojans, Ransomware, Worms e Botnets.
- **Aula 03 (Fator Humano):** Engenharia Social, Spear Phishing, Baiting e Pretexting.

O Desafio de Hoje (Aula 04)

"Compreender os vetores de ataque não basta. Como desenhar e implementar controles técnicos capazes de prevenir, detectar e conter ameaças reais?"

Transição do diagnóstico de riscos para a **Arquitetura Ativa de Defesa**.

Defesa em Profundidade

Princípio da Segurança em Camadas

Nenhuma ferramenta isolada é 100% infalível. A estratégia de **Defesa em Profundidade (Defense-in-Depth)** aplica múltiplos controles sobrepostos.

Se um atacante comprometer o percurso externo, as camadas subsequentes devem retardar, detectar ou mitigar o avanço do incidente.

CADEIA DE PROTEÇÃO:

Políticas → Segurança Física → Perímetro → Rede Interna → Endpoint → Aplicação → Dados



Categorização dos Mecanismos



Segurança de Perímetro & Rede

- **Firewall:** Filtro baseado em portas, IPs e estados.
- **IDS / IPS:** Análise heurística e por assinaturas.
- **VPN & Proxy:** Túnel cifrado e intermediação web.
- **Segmentação / DMZ:** Isolamento de tráfego.



Segurança de Endpoint

- **Antivírus (NGAV):** Bloqueio local contra malwares.
- **EDR:** Telemetria e isolamento preventivo.
- **Patch Management:** Correção contínua de CVEs.
- **Hardening:** Desativação de portas e serviços.



Identidade & Proteção de Dados

- **MFA / 2FA:** Múltiplos fatores de acesso.
- **POLP:** Menor privilégio possível.
- **Criptografia:** Em repouso (At-Rest) e trânsito.
- **Backup Imutável:** Proteção anti-ransomware.

Firewall vs. IDS vs. IPS

Mecanismo	Função Principal	Modo de Operação	Ação em Ataque	Camada OSI Foco
Firewall	Filtragem de pacotes com base em tabela de regras (IP, Porta, Protocolo).	Em linha (In-Line) no tráfego de rede.	Permite ou Bloqueia explicitamente a conexão.	Camada 3 (Rede) e Camada 4 (Transporte). NGFW atua até L7.
IDS (Intrusion Detection System)	Monitoramento passivo de cópias de pacotes (Port Mirroring/SPAN) buscando anomalias.	Fora de linha (Out-of-Band / Cópia do tráfego).	Alerta e Notifica o SOC. Não intervém no fluxo.	Camada 3 até Camada 7 (Análise profunda de pacotes - DPI).
IPS (Intrusion Prevention System)	Inspeção ativa e em tempo real para interceptar explorações de vulnerabilidades.	Em linha (In-Line) interceptando os pacotes.	Bloqueia, descarta e derruba a conexão maliciosa.	Camada 3 até Camada 7 (Prevenção ativa com assinatura e heurística).

Endpoint: Antivírus vs. EDR

Antivírus Tradicional (AV)

- **Mecanismo:** Baseado primordialmente em repositório de assinaturas conhecidas (MD5/SHA256).
- **Limitação:** Ineficaz contra malwares inéditos (Zero-Day) ou ataques Fileless (sem arquivo em disco).
- **Visão:** Reativa e pontual no arquivo suspeito localizado no dispositivo local.

EDR (Endpoint Detection & Response)

- **Mecanismo:** Coleta contínua de telemetria do sistema (processos, registros, conexões e memória).
- **Inteligência:** Identifica comportamentos anômalos usando IA e análise correlacionada em nuvem.
- **Capacidade de Resposta:** Permite isolar remotamente a máquina da rede e reverter alterações maliciosas.

Controle de Tráfego e Perímetro



VPN (Virtual Private Network): Estabelece um túnel criptografado (IPsec/TLS) sobre redes públicas, garantindo confidencialidade e autenticidade para colaboradores remotos.



Proxy Corporativo: Atua como intermediário das requisições web. Realiza inspeção de conteúdo, cache local, autenticação e bloqueio de categorias de sites maliciosos.



Segmentação de Rede & VLANs: Divisão da rede física em zonas lógicas isoladas, restringindo o movimento lateral do atacante caso um setor seja comprometido.



DMZ (Zona Desmilitarizada): Sub-rede exposta que abriga serviços públicos (Web, DNS), isolando-os da rede interna onde residem os dados sensíveis.

Gestão de Identidade & Zero Trust



Múltiplos Fatores (MFA)

Exige ao menos 2 fatores distintos:

- **Algo que você sabe:** Senha / PIN.
- **Algo que você possui:** Token / App OTP.
- **Algo que você é:** Biometria.

Neutraliza 99% dos ataques de credential stuffing.



Princípio do Menor Privilégio

- Todo usuário e aplicação deve ter apenas as permissões estritamente necessárias para sua função.
- Bloqueio de privilégios de Administrador local em estações de trabalho convencionais.



Arquitetura Zero Trust

- **Premissa Central:** "Nunca confie, sempre verifique".
- A localização dentro da rede interna não concede confiança implícita.
- Validação contínua de identidade, dispositivo e postura de segurança.

Proteção de Dados & Backup

Estratégia de Backup 3-2-1-1-0

- **3** Cópias de dados no total.
- **2** Meios de armazenamento diferentes (ex: Disco + Nuvem).
- **1** Cópia fora do ambiente principal (Offsite).
- **1** Cópia **Offline / Imutável** (Proteção WORM contra Ransomware).
- **0** Erros após testes periódicos de restauração (Restore Test).

Criptografia & Prevenção de Vazamentos

- **Criptografia At-Rest (Repouso):** AES-256 em discos rígidos e bancos de dados para impedir extração física.
- **Criptografia In-Transit (Trânsito):** TLS 1.3 obrigatório em toda comunicação interna e externa.
- **DLP (Data Loss Prevention):** Inspeção de saída de arquivos sensíveis por e-mail ou USB.

Estudo de Caso: Incidente TechSafe

100

Estações Infectadas & Operação Paralisada

Análise Forense do Cenário Real

Perfil: Empresa de tecnologia com 100 colaboradores, servidor de arquivos central, aplicação web pública e acesso Wi-Fi corporativo.

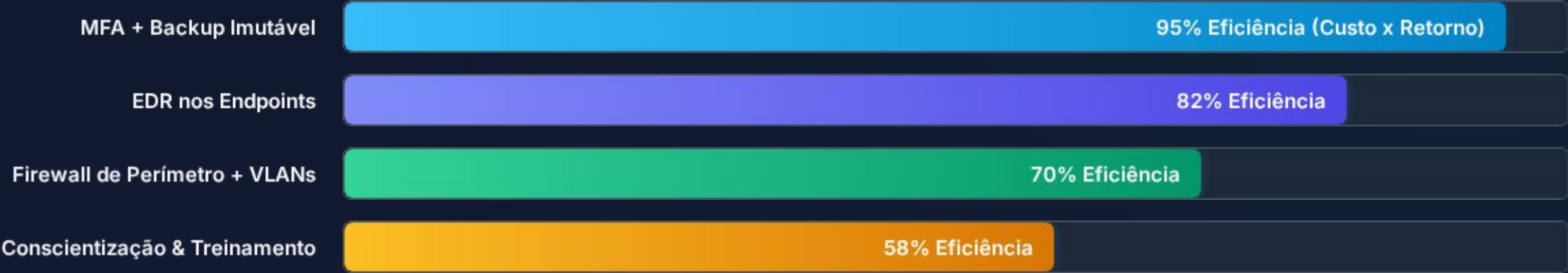
Cadeia do Incidente:

1. Usuário do Financeiro abre anexo com malware em Phishing.
2. A ausência de EDR e privilégios locais permitiu a execução do arquivo.
3. Rede plana (sem segmentação) permitiu movimentação lateral e criptografia do Servidor Central em poucas horas.

Arquitetura Recomendada



Priorização de Investimentos



Atividade Prática em Grupo



1. Formação de Grupos

Escolher um cenário de atuação:

- **Grupo A:** Hospital Universitário
- **Grupo B:** Fintech Bancária
- **Grupo C:** Instituição de Ensino
- **Grupo D:** Software House SaaS



2. Requisitos do Projeto

Desenhar a solução considerando:

- Posicionamento de Firewall, IDS/IPS e DMZ.
- Definição da política de Endpoint (AV/EDR).
- Plano de Autenticação (MFA) e Política de Backup.



3. Pitch de 3 minutos (Aula 05)

Apresentação Obrigatória na próxima aula:

Apresentar a arquitetura, justificando tecnicamente as escolhas e a distribuição do orçamento de defesa.

Perguntas & Discussão

Aprofundamos a aplicação prática de Firewall, IDS/IPS, EDR, VPN, Segmentação, MFA e Resiliência de Dados.

 Próxima Aula (Aula 05): **Testes de Invasão & Análise de Vulnerabilidades em Laboratório (Nmap, Wireshark, Kali Linux & Metasploit)**